

Комплексна система захисту інформації

Цільовий профіль безпеки
вищих спеціалізованих судів

Зміст

Зміст

1	AU	1
1.1	ПОДІЇ АУДИТУ (AU-2)	1
1.1.1	УЗАГАЛЬНЕННЯ ЗАПИСІВ ПРО АУДИТ З ДЕКІЛЬКОХ ДЖЕРЕЛ (AU-2(1))	3
1.1.2	ВИБІР ПОДІЇ АУДИТУ ЗА КОМПОНЕНТАМИ (AU-2(2))	3
1.1.3	ПЕРЕГЛЯД ТА ОНОВЛЕННЯ (AU-2(3))	3
1.1.4	ПРИВІЛЕЙОВАНІ ФУНКЦІЇ (AU-2(4))	3
2	SC	3
2.1	ДОСТУПНІСТЬ РЕСУРСІВ (SC-7)	3
2.1.1	ФІЗИЧНО ВІДДІЛЕНІ ПІДМЕРЕЖІ (SC-7(1))	4
2.1.2	ПУБЛІЧНИЙ ДОСТУП (SC-7(2))	4
2.1.3	ТОЧКИ ДОСТУПУ (SC-7(3))	4
2.1.4	ЗОВНІШНІ КОМУНІКАЦІЙНІ СЛУЖБИ (SC-7(4))	4
2.1.5	ВІДМОВА ЗА ЗАМОВЧУВАННЯМ - ДОЗВІЛ ЗА ВИНЯТКОМ (SC-7(5))	5
2.1.6	ВІДПОВІДЬ НА РОЗПІЗНАНІ ПОМИЛКИ (SC-7(6))	6
2.1.7	ЗАПОБІГАННЯ ПОДІЛУ ТУНЕЛЮВАННЯ ДЛЯ ВІДДАЛЕНИХ ПРИСТРОЇВ (SC-7(7))	6
2.1.8	ЗАХИСТ ПЕРИМЕТРА -МАРШРУТИЗАЦІЯ АВТЕНТИФІКОВАНИХ ПРОКСІ-СЕРВЕРІВ (SC-7(8))	6
2.1.9	ЗАХИСТ (SC-7(9))	6
2.1.10	ІЗОЛЮВАНІ ВІД ІНШИХ ВНУТРІШНІХ КОМПОНЕНТІВ СИСТЕМИ ШЛЯХОМ ВПРОВАДЖЕННЯ ФІЗИЧНО ВІДОКРЕМЛЕНИХ ПІДМЕРЕЖ З КЕРОВАНИМИ ІНТЕРФЕЙСАМИ ДО ІНШИХ КОМПОНЕНТІВ СИСТЕМИ (SC-7(13))	7
2.2	ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)	7
2.3	ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ (SC-28)	8

Анотація

Цільовий профіль безпеки (ЦПБ) — індивідуальний для конкретної системи підприємства. Саме на його основі створюється/модернізується КЗЗІ. Включає лише додаткові вимоги (відмінності) відносно Галузевого профілю.

1. AU

1.1. ПОДІЇ АУДИТУ (AU-2)

а. Визначити типи подій, які система може реєструвати для підтримки функції аудиту: [Призначення: типи подій, визначені організацією, які система здатна реєструвати]; б. Координувати функції аудиту безпеки з іншими організаційними підрозділами, які вимагають інформації, пов'язаної з аудитом, для посилення взаємної підтримки та допомоги у виборі типів подій, що перевіряються; с. Визначити, які типи подій підлягають аудиту: [Призначення: визначені організацією події, що підлягають аудиту (підмножина подій, що підлягають аудиту, визначених в AU-2 а.), а також частота (або ситуація, що вимагає) проведення аудиту для кожної ідентифікованої події] d. Обґрунтувати, чому типи подій, що перевіряються, вважаються достатніми для підтримки розслідувань інцидентів (постфактум), пов'язаних з безпекою та приватністю; е. Перегляньте й оновіть типи подій, вибрані для журналювання [Призначення: частота, визначена організацією].

No: 1

Name: au_2_a

Type: string

Default: nil

Типи подій, які система здатна реєструвати, визначено для підтримки функції аудиту

No: 2

Name: au_2_b

Type: string

Default: nil

Функція аудиту безпеки координується з іншими підрозділами організації, які вимагають інформації, пов'язаної з аудитом, для посилення взаємної підтримки та допомоги у виборі типів подій, що перевіряються

No: 3

Name: au_2_c_01

Type: string

Default: nil

Типи подій (підмножина 02_ODP[01]) визначаються для реєстрації у системі; AU-

No: 4

Name: au_2_c_02

Type: string

Default: "щорічно"

Зазначені типи подій реєструються 02_ODP[03] частота або ситуація>; <AU-

No: 5

Name: au_2_d

Type: string

Default: nil

Надається обґрунтування, чому типи подій, що перевіряються, вважаються достатніми для підтримки розслідувань інцидентів (постфактум), пов'язаних з безпекою та конфіденційністю

No: 6

Name: au_2_e

Type: string

Default: "щорічно"

Переглядаються та оновлюються типи подій, вибрані для реєстрації, частота, у системі

No: 7

Name: au_2_odp_01

Type: string

Default: nil

Визначено типи подій, які система може реєструвати для підтримки функції аудиту

No: 8

Name: au_2_odp_02

Type: string

Default: nil

Визначено типи подій (підмножина AU-02_ODP[01]) що підлягають аудиту у системі

No: 9

Name: au_2_odp_03

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено частоту або ситуацію, що вимагає проведення аудиту для кожної ідентифікованої події

No: 10
Name: au_2_odp_04
Type: string
Default: "щорічно"

Частота перегляду та оновлення типів подій, обраних для журналювання

1.1.1. УЗАГАЛЬНЕННЯ ЗАПИСІВ ПРО АУДИТ З ДЕКІЛЬКОХ ДЖЕРЕЛ (AU-2(1))

No: 1
Name: au_2_1_01
Type: list
Default: ["login", "logout", "failed_attempt"]

ПОДІЇ АУДИТУ - УЗАГАЛЬНЕННЯ ЗАПИСІВ ПРО АУДИТ З ДЕКІЛЬКОХ ДЖЕРЕЛ [Вилучено: Включено в AU-12]. AU-02(02) ПОДІЇ АУДИТУ - ВИБІР ПОДІЇ АУДИТУ ЗА КОМПОНЕНТАМИ [Вилучено: Включено в AU-12]

1.1.2. ВИБІР ПОДІЇ АУДИТУ ЗА КОМПОНЕНТАМИ (AU-2(2))

Немає параметрів для цього контролю.

1.1.3. ПЕРЕГЛЯД ТА ОНОВЛЕННЯ (AU-2(3))

No: 1
Name: au_2_3_01
Type: list
Default: ["login", "logout", "failed_attempt"]

ПОДІЇ АУДИТУ - ПЕРЕГЛЯД ТА ОНОВЛЕННЯ [Вилучено: Включено в AU-02]

1.1.4. ПРИВІЛЕЙОВАНІ ФУНКЦІЇ (AU-2(4))

No: 1
Name: au_2_4_01
Type: list
Default: ["login", "logout", "failed_attempt"]

ПОДІЇ АУДИТУ - ПРИВІЛЕЙОВАНІ ФУНКЦІЇ [Вилучено: Включено в AC-06(09)]

2. SC

2.1. ДОСТУПНІСТЬ РЕСУРСІВ (SC-7)

а. Контролювати та управляти зв'язком на зовнішньому периметрі системи та на ключових внутрішніх периметрах всередині системи. б. Реалізувати підмережі для загальнодоступних компонентів системи, які є [Вибір: фізично; логічно] відділені від внутрішніх мереж організації. с. Підключатися до зовнішніх мереж або систем тільки через керовані інтерфейси, що складаються з пристроїв захисту периметру, і розташованих відповідно до архітектури

безпеки та приватності організації.

Немає параметрів для цього контролю.

2.1.1. ФІЗИЧНО ВІДДІЛЕНІ ПІДМЕРЕЖІ (SC-7(1))

No: 1

Name: sc_7_1_01

Type: string

Default: nil

ЗАХИСТ ПЕРИМЕТРА - ФІЗИЧНО ВІДДІЛЕНІ ПІДМЕРЕЖІ [Вилучено: включено до SC-7]]

2.1.2. ПУБЛІЧНИЙ ДОСТУП (SC-7(2))

No: 1

Name: sc_7_2_01

Type: string

Default: nil

ЗАХИСТ ПЕРИМЕТРА - ПУБЛІЧНИЙ ДОСТУП [Вилучено: включено до SC-7]]

2.1.3. ТОЧКИ ДОСТУПУ (SC-7(3))

No: 1

Name: sc_7_3_01

Type: integer

Default: 3

Обмежена кількість зовнішніх мережевих підключень до системи

2.1.4. ЗОВНІШНІ КОМУНІКАЦІЙНІ СЛУЖБИ (SC-7(4))

No: 1

Name: sc_7_4_a

Type: string

Default: nil

Реалізовано керований інтерфейс для кожної зовнішньої телекомунікаційної послуги

No: 2

Name: sc_7_4_b

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Встановлена політика потоку трафіку для кожного керованого інтерфейсу

No: 3

Name: sc_7_4_c_01

Type: string

Default: nil

Захищена конфіденційність інформації, що передається через кожен інтерфейс

No: 4

Name: sc_7_4_c_02

Type: string

Default: nil

Захищена цілісність інформації, що передається через кожен інтерфейс

No: 5

Name: sc_7_4_d

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Задokumentовано кожен виняток з політики управління трафіком з обґрунтуванням місії або бізнес-потреби, а також тривалості такої потреби

No: 6

Name: sc_7_4_e_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Переглядаються винятки з політики потоку трафіку частота

No: 7

Name: sc_7_4_e_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Потрібно видалити винятки з політики потоку трафіку, які більше не підтримуються чітко визначеною місією або бізнеспотребою

No: 8

Name: sc_7_4_f

Type: string

Default: nil

Запобігається несанкціонований обмін управління із зовнішніми мережами

No: 9

Name: sc_7_4_g

Type: string

Default: nil

Публікується інформація, яка дозволяє віддаленим мережам виявляти несанкціонований трафік площини керування з внутрішніх мереж

No: 10

Name: sc_7_4_h

Type: string

Default: nil

Фільтрується несанкціонований трафік з зовнішніх мереж. трафіком плану

No: 11

Name: sc_7_4_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено періодичність перегляду винятків з політики управління інформаційними потоками

2.1.5. ВІДМОВА ЗА ЗАМОВЧУВАННЯМ - ДОЗВІЛ ЗА ВИНЯТКОМ (SC-7(5))

Немає параметрів для цього контролю.

2.1.6. ВІДПОВІДЬ НА РОЗПІЗНАНІ ПОМИЛКИ (SC-7(6))

No: 1
Name: sc_7_6_01
Type: string
Default: nil

ЗАХИСТ ПЕРИМЕТРА - ВІДПОВІДЬ НА РОЗПІЗНАНІ ПОМИЛКИ [Вилучено: включено до SC-7(18)]

2.1.7. ЗАПОБІГАННЯ ПОДІЛУ ТУНЕЛЮВАННЯ ДЛЯ ВІДДА- ЛЕНИХ ПРИСТРОЇВ (SC-7(7))

No: 1
Name: sc_7_7_01
Type: string
Default: "автоматизований засіб моніторингу"

Запобігається розділеному тунелюванню для віддалених пристроїв, що підключаються до систем організації, якщо розділене тунелюванню не захищено за допомогою засоби захисту

No: 2
Name: sc_7_7_odp
Type: string
Default: nil

Визначені гарантії безпечного прокладання розділеному тунелюванню

2.1.8. ЗАХИСТ ПЕРИМЕТРА -МАРШРУТИЗАЦІЯ АВТЕНТИ- ФІКОВАНИХ ПРОКСІ-СЕРВЕРІВ (SC-7(8))

No: 1
Name: sc_7_8_01
Type: string
Default: nil

SC-07(08) _ODP[01] внутрішній комунікаційний трафік> спрямовується до <SC-07(08) _ODP[02] зовнішніх мереж> через автентифіковані проксі-сервери на керованих інтерфейсах

2.1.9. ЗАХИСТ (SC-7(9))

No: 1
Name: sc_7_9_a_01
Type: string
Default: nil

Виявлено вихідний комунікаційний трафік, що становить загрозу для зовнішніх систем

No: 2
Name: sc_7_9_a_02
Type: string
Default: nil

Заборонено вихідний комунікаційний трафік, що становить загрозу для зовнішніх систем

No: 3
Name: sc_7_9_b

Type: string

Default: nil

Перевіряється ідентичність внутрішніх пов'язаних з відмовою у зв'язку користувачів,

2.1.10. ІЗОЛЬОВАНІ ВІД ІНШИХ ВНУТРІШНІХ КОМПОНЕНТІВ СИСТЕМИ ШЛЯХОМ ВПРОВАДЖЕННЯ ФІЗИЧНО ВІДОКРЕМЛЕНИХ ПІДМЕРЕЖ З КЕРОВАНИМИ ІНТЕРФЕЙСАМИ ДО ІНШИХ КОМПОНЕНТІВ СИСТЕМИ (SC-7(13))

No: 1

Name: sc_7_13_01

Type: string

Default: "автоматизований засіб моніторингу"

Ізольовані засоби, механізми та компоненти підтримки інформаційної безпеки від інших внутрішніх компонентів системи шляхом впровадження фізично відокремлених підмереж з керованими інтерфейсами до інших компонентів системи

No: 2

Name: sc_7_13_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені інструменти, механізми та компоненти підтримки інформаційної безпеки, які мають бути ізольовані від інших внутрішніх компонентів системи

2.2. ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)

Встановити та управляти криптографічними ключами для криптографічних засобів, які використовуються в системі відповідно до [Призначення: визначені організацією вимоги до генерації, поширення, зберігання, доступу та знищення ключів].

No: 1

Name: sc_12_01

Type: string

Default: "AES-256-GCM"

Встановлюються криптографічні ключі, коли в системі використовується криптографія відповідно до < SC-12_ODP вимог >

No: 2

Name: sc_12_02

Type: string

Default: "AES-256-GCM"

Здійснюється управління криптографічними ключами, коли в системі використовується криптографія, відповідно до вимог

No: 3

Name: sc_12_odp

Type: string

Default: nil

Визначені вимоги до генерації, розповсюдження, зберігання, доступу та знищення ключів

2.3. ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ (SC-28)

Забезпечити [Вибір (один або кілька): конфіденційність; цілісність] [Призначення: визначена організацією інформація] в стані спокою.

No: 1

Name: sc_28_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {конфіденційність; цілісність}

No: 2

Name: sc_28_odp_02

Type: string

Default: nil

Є інформація в стані спокою, яка потребує захисту